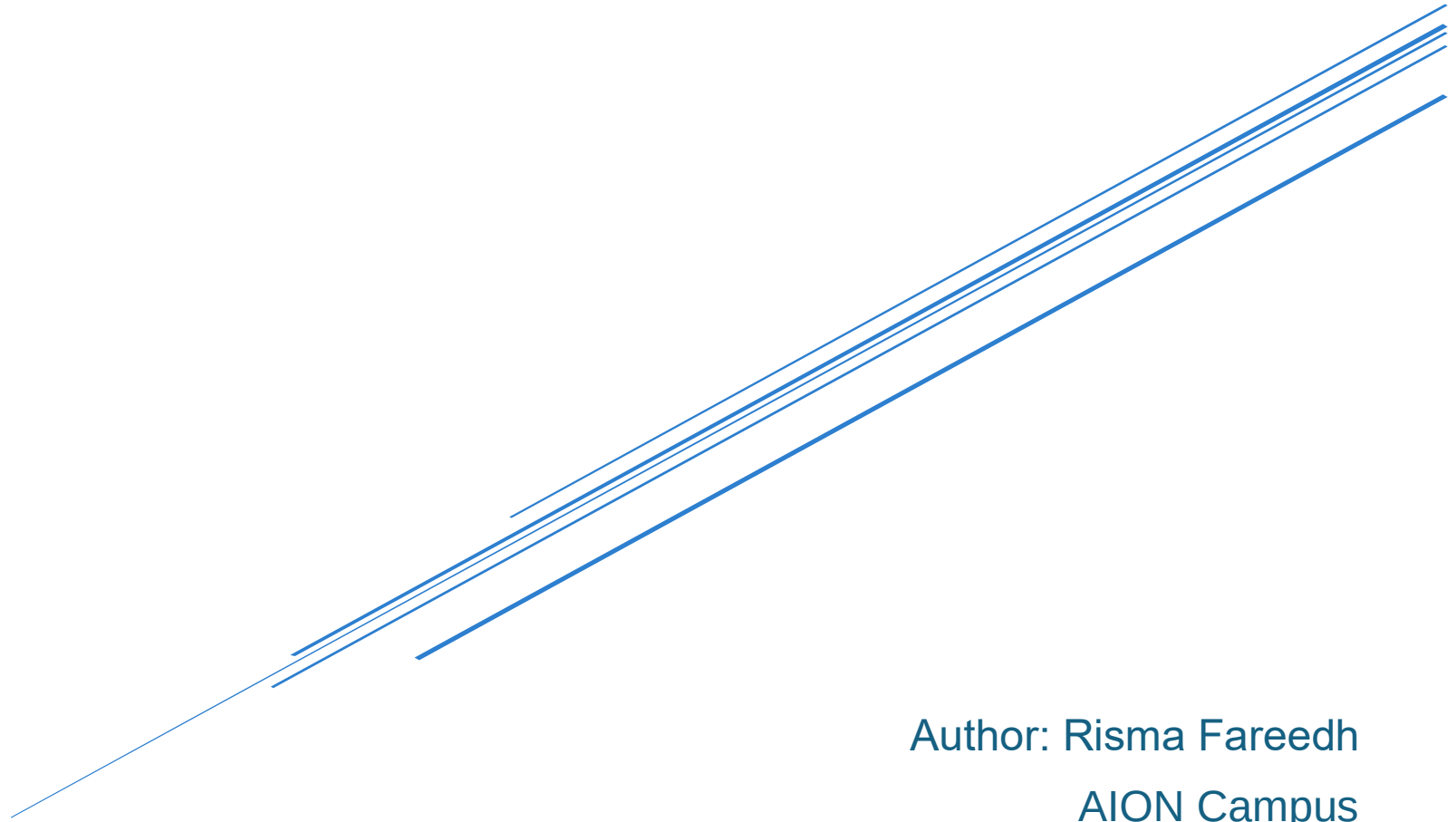


ISO/IEC 27001:2022 STATEMENT OF APPLICABILITY (SOA)

For Banking Industry



Author: Risma Fareedh

AION Campus

Governance, Risk & Compliance (GRC)

Q Bank: Statement of Applicability (SoA) – ISO/IEC 27001:2022 Annex A Controls**Q Bank: Statement of Applicability (SoA) – ISO/IEC 27001:2022**

Control ID	Control Name	Applicability (Yes/No)	Justification	Implementation Status	Included in ISMS? (Yes/No)	Remarks
A.5.1	Policies for information security	Yes	Required to define and communicate ISMS objectives and direction	Partial	Yes	Draft policy exists, needs management approval
A.5.2	Information security roles and responsibilities	Yes	Ensure roles and responsibilities are defined for security	Partial	Yes	RACI matrix prepared; ongoing updates needed
A.5.3	Segregation of duties	Yes	Reduce risk of fraud and error	Partial	Yes	Segregation implemented in IT & finance; some gaps in admin processes
A.5.4	Management responsibilities	Yes	Demonstrate leadership and commitment to ISMS	Yes	Yes	Top management involvement established; quarterly reviews planned
A.5.5	Contact with authorities	Yes	Required for incident reporting and compliance	Yes	Yes	Formal contacts with regulators maintained
A.5.6	Contact with special interest groups	No	Not applicable at present	N/A	No	No current engagement required
A.5.7	Threat intelligence	Yes	Required to identify emerging security threats	Partial	Yes	Initial threat intel reports received; process needs formalization

Q Bank: Statement of Applicability (SoA) – ISO/IEC 27001:2022 Annex A Controls

A.5.8	Information security in project management	Yes	Ensure security considerations in projects	Partial	Yes	Some project guidelines include security; needs standardization
A.5.9	Inventory of information and other assets	Yes	To identify and manage assets effectively	Partial	Yes	Asset register in progress; some assets missing
A.5.10	Acceptable use of information and other assets	Yes	Define permitted use of resources	Partial	Yes	Draft policy in place; awareness required
A.5.11	Return of assets	Yes	Ensure recovery of assets on exit of personnel	Partial	Yes	Exit checklist exists; formal tracking needed
A.5.12	Classification of information	Yes	Protect confidentiality and integrity	Partial	Yes	Classification scheme drafted; needs formal approval
A.5.13	Labelling of information	Yes	Support proper handling of information	Partial	Yes	Labels applied inconsistently; procedure formalization required
A.5.14	Information transfer policies and procedures	Yes	Secure information transfer internally and externally	Partial	Yes	Email encryption and secure file transfer implemented; policy needs update
A.5.15	Access control policy	Yes	Restrict access to authorized personnel	Partial	Yes	Role-based access control implemented; monitoring needs enhancement
A.6.1.1	Actions to address risks and opportunities	Yes	Align ISMS with organizational risks	Partial	Yes	Risk assessment methodology under development
A.6.1.2	Information security risk assessment	Yes	Identify and analyze risks	No	No	Risk assessment methodology being developed

Q Bank: Statement of Applicability (SoA) – ISO/IEC 27001:2022 Annex A Controls

A.6.1.3	Information security risk treatment	Yes	Implement risk treatments	Partial	Yes	SoA and risk treatment plan in progress
A.6.2	Information security objectives and planning	Yes	Set measurable ISMS objectives	Partial	Yes	Objectives drafted for key units; needs full coverage
A.7.1	Resources	Yes	Provide adequate resources for ISMS	Yes	Yes	Budget allocated for security tools and monitoring
A.7.2	Competence	Yes	Ensure staff competence	Partial	Yes	Training planned for all departments
A.7.3	Awareness	Yes	Ensure staff awareness of ISMS	Partial	Yes	Awareness program under development
A.7.4	Communication	Yes	Internal and external ISMS communication	Partial	Yes	Communication procedures drafted
A.8.1	Operational planning and control	Yes	Manage security of operations	Partial	Yes	Procedures documented; need monitoring
A.8.2	Information security risk assessment	Yes	Identify and analyze risks	No	No	Risk assessment methodology being developed
A.8.3	Information security risk treatment	Yes	Implement risk treatments	Partial	Yes	SoA and risk treatment plan in progress
A.8.4	Statement of applicability	Yes	Ensure control applicability defined	No	No	Initial draft SoA under review
A.8.5	Information classification	Yes	Proper classification of data	Partial	Yes	Classification scheme drafted
A.8.6	Information labelling	Yes	Support secure handling of information	Partial	Yes	Labelling process to be standardized

Q Bank: Statement of Applicability (SoA) – ISO/IEC 27001:2022 Annex A Controls

A.8.7	Information handling	Yes	Secure processing and storage	Partial	Yes	Handling procedures drafted
A.8.8	Media handling	Yes	Protect storage media	Partial	Yes	Media management policy under review
A.8.9	Access control	Yes	Restrict information access	Partial	Yes	RBAC implemented; auditing required
A.8.10	Cryptography	Yes	Protect confidentiality and integrity	Partial	Yes	Encryption applied selectively; policy needed
A.8.11	Physical and environmental security	Yes	Protect premises and equipment	Partial	Yes	Physical controls implemented; improvements needed
A.8.12	Operations security	Yes	Secure daily operations	Partial	Yes	Operational procedures documented
A.8.13	Communications security	Yes	Protect information in networks	Partial	Yes	Secure protocols implemented
A.8.14	System acquisition, development and maintenance	Yes	Security embedded in SDLC	Partial	Yes	Secure coding guidelines drafted
A.8.15	Supplier relationships	Yes	Manage third-party risks	Partial	Yes	Vendor risk assessments in progress
A.8.16	Information security incident management	Yes	Detect and respond to incidents	Partial	Yes	Incident response plan drafted
A.8.17	Information security aspects of business continuity management	Yes	Ensure ISMS continuity	Partial	Yes	BCP/DR plans exist; testing scheduled

Q Bank: Statement of Applicability (SoA) – ISO/IEC 27001:2022 Annex A Controls

A.8.18	Compliance	Yes	Meet legal and regulatory requirements	Partial	Yes	Compliance framework under review
A.9.1	Monitoring, measurement, analysis and evaluation	Yes	Track ISMS performance	Partial	Yes	KPIs and dashboards under development
A.9.2.1	Internal audit – general	Yes	Ensure ISMS compliance	No	No	Audit schedule to be prepared
A.9.2.2	Internal audit program	Yes	Maintain audit program	No	No	Annual audit program draft pending
A.9.3.1	Management review – general	Yes	Top management review	Partial	Yes	Quarterly review planned
A.9.3.2	Management review inputs	Yes	Inputs include risks, audit results, feedback	No	No	Agenda to be defined
A.9.3.3	Management review results	Yes	Document outputs and decisions	No	No	Action items to be tracked
A.10.1	Continual improvement	Yes	Improve ISMS effectiveness	Partial	Yes	Improvement log to be established
A.10.2	Nonconformity and corrective action	Yes	Correct deviations in ISMS	No	No	CAPA process under development
A.11.1	Physical security perimeter	Yes	Protect premises	Partial	Yes	Physical controls partially implemented
A.11.2	Physical entry controls	Yes	Restrict access to secure areas	Partial	Yes	Card access implemented; monitoring needed
A.11.3	Securing offices, rooms, and facilities	Yes	Protect sensitive areas	Partial	Yes	Locks and CCTV partially implemented

Q Bank: Statement of Applicability (SoA) – ISO/IEC 27001:2022 Annex A Controls

A.11.4	Protecting against external and environmental threats	Yes	Reduce environmental risk	Partial	Yes	Fire suppression and power backup in place
A.11.5	Working in secure areas	Yes	Prevent unauthorized disclosure	Partial	Yes	Security signage and procedures drafted
A.11.6	Equipment security	Yes	Prevent equipment loss or damage	Partial	Yes	Equipment inventory maintained
A.11.7	Supporting utilities	Yes	Ensure critical utilities are protected	Partial	Yes	UPS and backup generators available
A.11.8	Cabling security	Yes	Protect communication and power cables	Partial	Yes	Cables secured in restricted areas
A.11.9	Equipment maintenance	Yes	Preventing security compromise	Partial	Yes	Maintenance logs maintained
A.11.10	Secure disposal or reuse of equipment	Yes	Protect data when decommissioning assets	Partial	Yes	Disposal procedures drafted
A.12.1	Operational procedures and responsibilities	Yes	Standardize operations	Partial	Yes	SOPs documented
A.12.2	Change management	Yes	Securely manage changes	Partial	Yes	Change control process implemented
A.12.3	Capacity management	Yes	Ensure system availability	Partial	Yes	Monitoring in place
A.12.4	Separation of development, testing and operational environments	Yes	Prevent unauthorized access or errors	Partial	Yes	Environmental separation partially implemented
A.13.1	Network security management	Yes	Protect information in networks	Partial	Yes	Firewalls and IDS deployed

Q Bank: Statement of Applicability (SoA) – ISO/IEC 27001:2022 Annex A Controls

A.13.2	Information transfer	Yes	Secure transmission of information	Partial	Yes	Encryption and secure protocols applied
A.14.1	Security requirements of information systems	Yes	Ensure secure system design	Partial	Yes	Secure development guidelines drafted
A.14.2	Security in development and support processes	Yes	Embed security in SDLC	Partial	Yes	Security reviews implemented
A.14.3	Test data	Yes	Protect data during testing	Partial	Yes	Anonymization procedures drafted
A.15.1	Information security in supplier relationships	Yes	Protect supply chain	Partial	Yes	Vendor security assessments in progress
A.15.2	Supplier service delivery management	Yes	Ensure supplier controls	Partial	Yes	SLA and contract clauses drafted
A.16.1	Management of information security incidents and improvements	Yes	Detect and respond to incidents	Partial	Yes	Incident management process drafted
A.17.1	Information security continuity	Yes	Business continuity of critical systems	Partial	Yes	BCP and DR plans partially tested
A.17.2	Redundancies	Yes	Ensure system resilience	Partial	Yes	Redundant systems in place
A.18.1	Compliance with legal and contractual requirements	Yes	Ensure regulatory compliance	Partial	Yes	Compliance monitoring under development
A.18.2	Information security reviews	Yes	Monitor and review ISMS	Partial	Yes	Periodic management review planned

Q Bank: Statement of Applicability (SoA) – ISO/IEC 27001:2022 Annex A Controls